COMPTIA SECURITY+ SY0-701 | DOMAIN 4 · SECURITY OPERATIONS (28%)

Security+ 4.8 · Log Data

Mestre CyberSec · **Lesson 4.8 — Log Data** (13:41) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Executive Lesson Summary: Log: firewall (regra/IP/porta); aplicação (login/erro); endpoint (Windows Event, Sysmon); OS (syslog Linux, Event Viewer Windows); network (netflow/DNS queries); proxy log. RETENÇÃO (quanto tempo — por lei/auditoria); PROTEÇÃO (quem lê/altera); centralização no SIEM.

💡 Key Exam Highlights & Critical Concepts

- Cole log de TUDO: firewall+app+endpoint+rede+cloud
- Retention por lei: 1 ano é comum; log protegido contra alteração

🎯 Exam Tips & Typical CompTIA Scenarios

- 'centralized log repository'=SIEM; 'how long to keep'=retention

🚨 Beyond the Video: Official Exam Concepts, Protocols & Traps (Section 4.8 — Log Data)

Why is this advanced coverage required for SY0-701?: Video lectures provide foundational concepts, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

• Security Information and Event Management (SIEM)
A centralized platform that collects, aggregates, correlates, and analyzes log data from firewalls, endpoints, applications, networks, and cloud sources in real time. It provides alerting, dashboards, and forensic search capabilities across the entire organization.

⚠️ ***Exam Trap:*** *Qualquer menção a 'centralized log repository', 'aggregate logs from multiple sources' ou 'correlate events' = SIEM. É a resposta padrão para centralização de logs.*

• Syslog (SYSLOG)
The standard logging protocol (RFC 5424) used primarily on Linux/Unix systems and network devices to send event messages to a central log server. Messages are categorized by facility and severity level, and typically use UDP port 514.

⚠️ ***Exam Trap:*** *Linux + dispositivos de rede (roteadores, switches) = Syslog. Se a questão fala de logs de Linux ou envio de logs para servidor remoto, pense em Syslog, não em Event Viewer.*

• Windows Event Viewer (N/A)
The native Windows tool for viewing operating system, application, and security event logs. Key logs include Application, System, and Security (which records logons, privilege use, and audit policy events).

⚠️ ***Exam Trap:*** *Windows = Event Viewer / Event Logs; Linux = Syslog. Logons e eventos de auditoria no Windows estão no log de SECURITY. Não confunda os dois ecossistemas.*

• System Monitor (Sysmon) (SYSMON)
A Windows Sysinternals tool that provides detailed endpoint logging beyond standard Event Viewer, capturing process creation, network connections, file changes, and driver loads. It is commonly used for threat hunting and detecting malicious activity on endpoints.

⚠️ ***Exam Trap:*** *Se a questão pede logs DETALHADOS de endpoint (processos criados, conexões de rede por processo), a resposta é Sysmon, não o Event Viewer padrão.*

• NetFlow (N/A)
A network logging technology that collects metadata about traffic flows: source/destination IPs, ports, protocols, and volume — without capturing packet payloads. Used for traffic analysis, capacity planning, and detecting anomalous

network behavior.

⚠️ ***Exam Trap:*** *'Traffic metadata', 'who talked to whom, on which port, how much data' = NetFlow. Ele mostra metadados de fluxo, NÃO o conteúdo (isso seria packet capture/PCAP).*

• Log Retention (N/A)

The policy defining how long log data must be stored before archival or deletion. Retention periods are driven by legal, regulatory, and audit requirements (e.g., one year is common), balancing compliance needs against storage costs.

⚠️ ***Exam Trap:*** *'How long to keep logs?' = retention policy. A resposta quase sempre envolve leis/regulamentações/auditoria, não preferência técnica. Retenção varia por tipo de log e setor.*

• Log Integrity and Protection (WORM)

Controls ensuring logs cannot be altered or deleted after creation, such as Write Once Read Many storage, hashing, digital signatures, and strict access control lists. Protecting log integrity is critical because attackers routinely try to erase evidence of their activity.

⚠️ ***Exam Trap:*** *Perguntas sobre 'prevent log tampering' ou 'who can read/modify logs' apontam para integridade: WORM, hashing, acesso restrito e envio imediato ao SIEM (fora do alcance do atacante que comprometeu o host).*

• Proxy Logs (N/A)

Logs generated by forward proxies and web filters that record every URL requested, user identity, timestamps, categories, and filtering/block decisions. They are essential for investigating web-borne threats, data exfiltration, and acceptable use violations.

⚠️ ***Exam Trap:*** *Se a questão pergunta 'which log shows which websites a user visited' ou 'URL filtering decisions', a resposta é proxy log — não firewall log (que mostra IPs/portas, não URLs completas).*

✅ Authentic Practice Questions (10 Real Exam Scenarios)

Scenario-based exam questions. Complete explanations and distractor analysis are provided in the answer key below.

QUESTION 1 · EXAM SCENARIO

A SOC analyst at a financial services company is reviewing firewall logs after receiving an alert about suspicious outbound traffic. The alert indicates a specific firewall rule was triggered. Which field in the firewall log entry will directly identify which firewall policy or rule caused the traffic to be permitted, denied, or dropped?

A) The destination IP address

B) The source MAC address

C) The rule ID, policy name, or action field

D) The packet TTL (Time To Live) value

QUESTION 2 · EXAM SCENARIO

An incident responder needs to determine which process spawned a suspicious executable on a Windows workstation, including the parent-child process relationship and the full command-line arguments used. The standard Security log does not contain this level of detail. Which tool should the security team deploy to capture this endpoint telemetry?

A) Windows Event Viewer with the Application log only

B) Performance Monitor (perfmon)

C) Microsoft Sysmon (System Monitor)

D) Task Manager historical logs

QUESTION 3 · EXAM SCENARIO

A mid-sized healthcare organization has logs scattered across individual servers, firewalls, and endpoints. Analysts are missing correlated attacks because a brute-force login on the VPN and a subsequent malware download on an endpoint are never reviewed together. Which architectural change best addresses this gap?

A) Increase the local log file size on each server

B) Forward all log sources to a centralized SIEM for correlation

C) Disable verbose logging to reduce noise

D) Rotate logs more frequently on each device

QUESTION 4 · EXAM SCENARIO

A company that processes credit card transactions must comply with PCI DSS Requirement 10.5.1 regarding audit log retention. The compliance officer asks the security team to verify that audit trails are being kept for the correct minimum period. For how long must PCI DSS audit logs be retained at a minimum?

A) 30 days

B) 90 days

C) At least 12 months (1 year)

D) 7 years

QUESTION 5 · EXAM SCENARIO

A security architect must design a log storage solution that prevents any user—including domain administrators—from modifying or deleting log entries after they are written, in order to satisfy legal hold and chain-of-custody requirements. Which storage characteristic must the solution provide?

A) RAID-6 redundancy

B) Write Once, Read Many (WORM) immutability

C) AES-256 encryption at rest

D) Daily tape backups to an offsite vault

QUESTION 6 · EXAM SCENARIO

A network engineer needs to capture traffic flow metadata (source/destination IPs and ports, packet counts, byte counts, timestamps) from the core router to feed the SIEM and detect volumetric anomalies and beaconing behavior. Full packet payloads are not required and storing them would be cost-prohibitive. Which technology is the most appropriate choice?

A) Full PCAP on every span port

B) NetFlow (or IPFIX) export from the router

C) SNMP polling of interface counters only

D) Syslog forwarding from the router's kernel

QUESTION 7 · EXAM SCENARIO

A security analyst is monitoring a Windows domain controller for potential password-spraying attacks. Which specific Event ID in the Windows Security log indicates a failed logon attempt and should be aggregated by the SIEM to detect this activity?

A) 4624 - An account was successfully logged on

B) 4625 - An account failed to log on

C) 4634 - An account was logged off

D) 4648 - A logon was attempted using explicit credentials

QUESTION 8 · EXAM SCENARIO

A Linux administrator is configuring rsyslog to forward authentication events (such as SSH logins and sudo usage) from the auth.log file to the central SIEM. Which syslog facility should be used to ensure the SIEM correctly categorizes and parses these authentication-related messages?

A) auth (or authpriv)

B) kern

C) daemon

D) user

QUESTION 9 · EXAM SCENARIO

A data loss prevention (DLP) investigation reveals that an employee exfiltrated sensitive design documents to a personal cloud storage account using HTTPS. The firewall cannot inspect the encrypted payload. However, the web proxy recorded every URL requested. Which log field is most useful for reconstructing the user's web activity during the incident?

A) DHCP lease time from the endpoint

B) NetFlow byte counters

C) Proxy log URL, user, and timestamp entries

D) Windows Event ID 4688 only

QUESTION 10 · EXAM SCENARIO

Threat intelligence has warned of a malware family that uses DNS tunneling to communicate with its command-and-control server. The DNS resolver logs are being forwarded to the SIEM. Which pattern in the DNS logs would most likely indicate this tunneling activity?

A) A high volume of NXDOMAIN responses for short, randomly generated subdomain labels under a single parent domain

B) A small number of A-record responses for well-known domains like google.com

C) Reverse PTR lookups for internal hostnames

D) AAAA (IPv6) responses for local servers

ANSWER KEY & COMPREHENSIVE DISTRACTOR EXPLANATIONS

Question 1: Option C — The rule ID, policy name, or action field

The rule ID, policy name, or action field directly identifies which firewall rule was matched. Source/destination IPs only identify endpoints, and TTL is a network layer field unrelated to policy decisions. Without the rule identifier, analysts cannot determine whether the traffic was blocked or allowed and why.

Question 2: Option C — Microsoft Sysmon (System Monitor)

Microsoft Sysmon is a Windows system service and device driver that logs detailed process creation (Event ID 1) including parent process, command line, hashes, and network connections—far beyond the default Security log. Performance Monitor tracks resource counters, Task Manager does not retain historical process data, and the Application log lacks process ancestry information.

Question 3: Option B — Forward all log sources to a centralized SIEM for correlation

A SIEM (Security Information and Event Management) centralizes log ingestion from disparate sources and correlates events using rules and analytics—essential for detecting multi-stage attacks that span firewalls, authentication, and hosts. Larger local logs, faster rotation, or disabling logging do not enable cross-source correlation.

Question 4: Option C — At least 12 months (1 year)

PCI DSS v4.0 Requirement 10.5.1 mandates retaining audit logs for at least 12 months, with the most recent 3 months immediately available for analysis. 30 or 90 days would not satisfy the standard; 7 years is the retention for some financial records but not the PCI DSS baseline.

Question 5: Option B — Write Once, Read Many (WORM) immutability

WORM (Write Once, Read Many) storage enforces immutability so that data, once written, cannot be altered or deleted—even by administrators—satisfying chain-of-custody and legal hold requirements. RAID-6 protects against disk failure but allows modification; encryption protects confidentiality but not integrity against tampering; backups alone do not prevent in-place modification of current logs.

Question 6: Option B — NetFlow (or IPFIX) export from the router

NetFlow (and its successor IPFIX) exports per-flow metadata—IPs, ports, packet/byte counts, timestamps, and protocol—ideal for SIEM analytics, anomaly detection, and long-term retention due to its compact size. Full PCAP is too expensive to store at scale; SNMP counters lack per-flow granularity; syslog from a router typically contains only device events, not traffic flows.

Question 7: Option B — 4625 - An account failed to log on

Event ID 4625 is logged each time a logon attempt fails and includes the source IP, account name, logon type, and failure reason—perfect for correlating password-spray patterns. 4624 is a successful logon (the opposite signal), 4634 is a logoff, and 4648 represents explicit-credential usage which is not the primary indicator of failed attempts.

Question 8: Option A — auth (or authpriv)

The 'auth' (and 'authpriv' for sensitive messages) facility is the standard syslog classification for authentication, authorization, and sudo events on Linux/UNIX. 'kern' is for kernel messages, 'daemon' for system daemons, and 'user' is the default generic facility—none specifically identify authentication events for proper SIEM parsing.

Question 9: Option C — Proxy log URL, user, and timestamp entries

Proxy logs record the requested URL, authenticated user, timestamp, and response codes—even when the payload is encrypted via HTTPS—making them the primary source for web activity reconstruction. DHCP lease data shows addressing, NetFlow shows volume/ports (not URLs), and Event ID 4688 shows process creation, none of which reveal the destination URL.

Question 10: Option A — A high volume of NXDOMAIN responses for short, randomly generated subdomain labels under a single parent domain

DNS tunneling typically manifests as a high volume of queries for high-entropy (random-looking) subdomains under a single attacker-controlled domain, with many NXDOMAIN responses due to the encoded/chunked nature of the data. Normal A-record lookups to popular sites, PTR lookups for internal hosts, and IPv6 responses for local servers are routine traffic patterns, not tunneling indicators.